

보도시점 2024. 5. 9.(목) 12:00 배포 2024. 5. 8.(수) 18:00

개인정보위, (주)골프존 개인정보 유출사고에 대해 과징금 75억 원, 과태료 540만 원 및 시정명령 부과

개인정보보호위원회(위원장 고학수, 이하 ‘개인정보위’)는 5월 8일(수) 제8회 전체회의를 열고, 개인정보보호 법규를 위반한 (주)골프존에 대해 총 75억 4백만 원의 과징금과 540만 원의 과태료를 부과하고, 동시에 시정명령 및 공표명령을 의결하였다.

(주)골프존은 지난해 11월 해커에 의한 랜섬웨어 공격을 받았고, 이 과정에서 해커는 알 수 없는 방법으로 (주)골프존 직원들의 가상사설망 계정정보*를 탈취하여 업무망 내 파일서버**에 원격접속('23.11.22.)하고 파일서버에 저장된 파일을 외부로 유출('23.11.22.~23.)한 후 다크웹에 공개하였다.

* 이 계정 중에는 서버 관리자 계정도 포함됨

** 윈도우의 공유폴더 기능을 이용, 임직원들의 PC에 파일서버의 폴더가 생성·공유

이로 인해 업무망 내 파일서버에 보관되어 있던 약 221만명 이상의 서비스 이용자 및 임직원의 개인정보(이름, 전화번호, 이메일, 생년월일, 아이디 등)가 유출되었고, 일부의 경우 주민등록번호(5,831명)와 계좌번호(1,647명)도 유출되었다.

개인정보위가 이번 유출사고에 대한 (주)골프존의 개인정보 보호법 준수 여부를 조사한 결과, 확인된 주요 위반사항은 다음과 같다.

< 안전조치의무 위반 >

먼저, (주)골프존은 전 직원이 사용하는 파일서버에 주민등록번호를 포함한 다량의 개인정보가 저장되어 공유되고 있다는 사실을 인지하지 못했고, 개인

정보파일이 보관되어있는 파일서버에 대한 주기적 점검 등 관리체계를 미흡하게 운영한 것으로 밝혀졌다.

구체적으로, 코로나19로 재택근무가 급증하자 (주)골프존은 새로운 가상사설망을 긴급히 도입하는 과정에서 외부에서 내부 업무망에 ID와 PW만으로 접속할 수 있도록 허용하였음에도, 업무망 안에 존재하는 파일서버에 대해 개인정보 유출 관련 보안위협을 검토하고 필요한 안전조치를 하지 않았다.

이로 인해 외부에서 서버로의 원격접속 등 불필요한 접근이 허용되었고, 서버 간의 원격접속과 업무망 내 모든 서버의 인터넷 통신이 허용되는 등 공유설정을 통한 개인정보 유출을 방지하기 위한 안전조치가 소홀하였다.

이에 해커는 탈취한 서버 관리자 계정으로 가상사설망을 통해 파일서버에 접근하고 파일서버에서 외부로 파일을 유출할 수 있었다.

< 주민등록번호 처리제한 및 개인정보 파기 위반 >

또한, 주민등록번호 등을 암호화하지 않고 파일서버에 저장·보관하고 있었고, 보유기간이 경과되거나, 처리목적 달성 등 불필요하게 된 최소 38만여명*의 개인정보를 파기하지 않은 위반행위가 있었다.

*** ▲ 준회원 중 현재 회원으로 확인되지 않은 383,365명의 정보, ▲ 임직원 정보 중 퇴사하여 보유 근거가 없는 2,916명의 정보, ▲ 인턴사원 및 전문연구요원 1,159명의 채용관련 정보, ▲ 기타 고객응대(VOC) 관련 이용자 및 점주의 개인정보 등**

개인정보위는 (주)골프존에 대해 보호법 제29조 안전조치의무 위반으로 과징금을 부과하고, 같은 법 제21조 개인정보 파기의무를 준수하지 않은 행위에 대해 과태료 부과를 결정하였다.

또한 ▲ 회사 내의 개인정보 처리흐름에 대한 면밀한 분석을 통한 실질적인 내부관리계획 수립·시행, ▲ 공유설정 등을 통해 개인정보가 유출되지 않도록 조치하는 등 안전조치의무 준수, ▲ 개인정보보호책임자의 위상과 역할 강화, ▲ 전 직원 대상 개인정보 보호 교육을 주기적으로 실시할 것을 시정명령한 동시에, 이러한 사실을 홈페이지 등에 공표하도록 명령하였다.

이번 처분은 지난해 기업 차원의 책임성을 강화하기 위해 개정('23. 3. 14. 개정, '23. 9. 15. 시행)한 개인정보 보호법 규정*이 실질적으로 적용된 첫 사례이다. 아울러 전통적으로 개인정보 처리가 많이 이루어지는 서비스 영역 뿐만 아니라 다양한 고객정보를 취급하는 내부 업무영역에서도 철저한 개인정보 보호조치가 적용되어야 함을 강조한 사례로, 이를 계기로 업무처리 전반에 개인정보 보호 수준이 향상될 것으로 기대한다.

* 과징금 상한액을 위반행위 관련 매출액 3%에서 전체 매출액 3%로 상향하고, 비례성이 확보되도록 과징금 산정시 위반행위와 관련없는 매출액을 제외함

[붙임] 위반내용 및 시정조치

담당 부서 <총 괄>	개인정보보호위원회 조사1과	책임자	과 장	강대현 (02-2100-3111)
		담당자	조사관	최현진 (02-2100-3120)
		담당자	조사관	최우석 (02-2100-3113)
<공 동>	한국인터넷진흥원 기업조사팀	책임자	팀 장	박대식 (061-820-1113)
		담당자	책 임	정진우 (061-820-1478)



더 아픈 환자에게 양보해 주셔서 감사합니다
가벼운 증상은 동네 병·의원으로

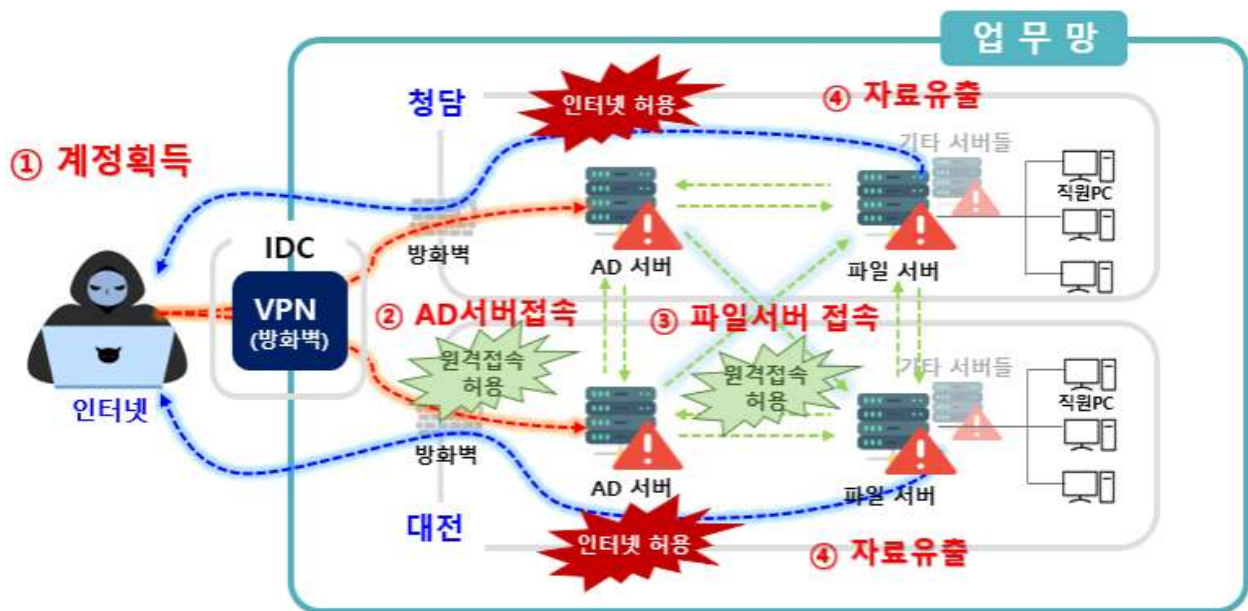


붙임 위반내용 및 시정조치

사업자명	위반 내용	위반 조항	시정조치(안)
(주)골프존	- 개인정보 파기 위반 - 주민등록번호 처리제한 위반 - 안전조치의무 위반	보호법 §21①, §24의2②, §29	- 과징금 75억 400만 원 - 과태료 540만 원 - 시정명령 - 공표명령*

* 공표명령은 개인정보 보호법 개정('23.9.15.)으로 신설된 처분 규정으로, 사업자 홈페이지 등에 과징금·과태료 등의 처분받은 사실을 공표하는 제도

< 개인정보 유출 과정 >



- 해커는 알 수 없는 방법으로 골프존 직원들의 가상사설망(VPN) ①**계정정보***를 탈취하였고, ②사용자 인증 및 권한부여 관리서버(AD서버) 및 ③파일서버에 원격접속('23.11.22.)하여 ④파일서버에 저장된 파일을 외부로 유출('23.11.22.~23.)한 후 다크웹에 공개함

* 이 계정 중에는 '파일서버'의 관리자 계정인면서 'AD 서버'의 관리자 계정도 포함됨